Pericope ERM - Master Technical Defense & Demo Manual

Major Project Title: A Resilience-First, Three-Tier Architecture for Full-Lifecycle Enterprise Risk Management

Authors: Srivatsan B (1AT23CG104), Raja Vishnu (1AT23CG080), Rithvik R (1AT23CG084), Niranthar M Javagal (1AT23CG071)

Academic Guide: Prof. Veena S, Department of Computer Science & Engineering, Atria Institute of Technology

Version: 3.5 (Detailed Technical Edition)

1. Executive Summary & Core Problem Statement

1.1 The Industry Problem (The "Spreadsheet Trap")

Over 70% of small to mid-sized enterprises (SMEs) manage their corporate risk registers, control matrices, and compliance tracking using **Microsoft Excel workbooks** and email chains. While spreadsheets are familiar, they introduce critical structural failures:

- **Lack of a Single Source of Truth:** Multiple conflicting workbook versions circulate across departments (Finance, IT, Operations).
- **Disconnected Qualitative and Quantitative Views:** When a control is tested, the 5x5 heatmap is rarely updated, causing reports to drift out of sync with actual organizational exposure.
- **Zero Tamper-Evident Auditability:** Spreadsheets have no native concept of maker-checker segregation of duties or immutable event logs, causing organizations to fail regulatory audits under **SOX Section 404**, **ISO 31000**, and **ISO/IEC 27001**.
- **Prohibitive Cost of Commercial Suites:** Enterprise tools like ServiceNow GRC or RSA Archer cost $50,000+/year and require months of configuration, putting them out of reach for growing teams.

1.2 The Solution: Pericope ERM

Pericope ERM provides an institutional-grade, full-lifecycle Governance, Risk, and Compliance platform deployed on a lightweight, three-tier architecture over an **Oracle Autonomous Database** schema. It unifies:

- RCSA assessment lifecycle workflows across departments.
- Dual mathematical scoring (S = L x I and Single Loss Expectancy SLE = S x $10,000).
- Open FAIR Monte Carlo probabilistic loss simulation.
- Real-time Key Risk Indicator (KRI) telemetry tracking.
- 1-Click Excel/CSV bulk risk register migration.
- Multi-stage Maker-Checker approval chains and 1-Click Board Pack PDF exports.

2. Deep-Dive Architecture & Computer Science Principles

2.1 The Three-Tier Resilient System

Pericope ERM is constructed around three decoupled, cooperating tiers rather than a monolithic backend:

- **Tier 1 (Client Presentation Tier):** Next.js 15 App Router + React 19 + TypeScript. Data caching is governed by TanStack Query with a 5-minute TTL. Local state is persisted via a typed `LocalStore` engine supporting cross-tab `storage` event listeners for 9 offline-tolerant modules.
- **Tier 2 (Backend-for-Frontend Gateway - `server.js`):** Node.js Express API proxy providing input sanitization (keyboard-mash rejection), uppercase Oracle case normalization (`toOracleCase`), and a strict 8-second circuit-breaker timeout.
- **Tier 3 (Enterprise Database Tier):** Oracle Autonomous Database (ADW) exposed through Oracle REST Data Services (ORDS) spanning 48 partitioned relational entities.

2.2 The In-Memory Shadow Store Fallback Pattern

To eliminate client-side freezing during upstream database latency or network dropouts:

- When a mutating request (`POST`/`PUT`) is received, the BFF starts an 8-second timer.
- If ORDS answers within 8 seconds, data is persisted and returned.
- If ORDS times out or is unreachable, the BFF catches the error, writes the record into an **In-Memory Shadow Store**, assigns a synthetic sequential identifier (`nextId()`), logs the user attribution, and returns a `201 Created` / `200 OK` response with `source: 'shadow'`.
- **Result:** The user interface never hangs, spinners never freeze, and users continue working seamlessly.

2.3 Database Hardening & Autonomous Audit Procedures

In Oracle databases, writing audit logs within the main transaction thread often causes deadlocks or `ORA-04098: trigger is invalid`. If an audit table write fails, Oracle's default behavior rolls back the entire business transaction.

The Pericope Remediation Fix (`fix_pericope_erm.sql`):

```
CREATE OR REPLACE PROCEDURE ERM_AUDIT_WRITE (









/
p_action IN VARCHAR2, p_entity IN VARCHAR2, p_entity_id IN VARCHAR2, p_desc IN VARCHAR2
) AS
PRAGMA AUTONOMOUS_TRANSACTION;
v_actor VARCHAR2(200);
BEGIN
v_actor := NVL(SYS_CONTEXT('USERENV','CLIENT_IDENTIFIER'), USER);
EXECUTE IMMEDIATE 'INSERT INTO ERM_TRN_AUDIT_LOG (...) VALUES (...)';
COMMIT;
EXCEPTION
WHEN OTHERS THEN ROLLBACK; -- Swallowed: Audit failure NEVER breaks business writes
END;
```

- **Theoretical Contribution:** `PRAGMA AUTONOMOUS_TRANSACTION` executes the audit insert in an independent transaction thread with its own commit scope.

3. The Mathematical Risk Engine & Quantification Models

3.1 Qualitative Composite Score Formula

Likelihood (L) and Impact (I) are selected from a 5-point ordinal scale ($L, I \in \{1, 2, 3, 4, 5\}$):

```
S = L × I      S ∈ [1, 25]
```

Severity Band Partitioning:

- **Low Severity (Acceptable):** 1 ≤ S ≤ 7 (Operates comfortably within risk appetite)
- **Medium Severity (Monitored):** 8 ≤ S ≤ 11 (Monitored via automated KRI telemetry)
- **High Severity (Elevated):** 12 ≤ S ≤ 15 (Mandatory mitigation & control testing)
- **Critical Severity (Unacceptable):** 16 ≤ S ≤ 25 (Immediate Board Risk Committee escalation)

3.2 Quantitative Single Loss Expectancy (SLE)

To translate qualitative matrix coordinates into tangible monetary exposure for financial stakeholders:

```
SLE = S × \$10{,000 = (L × I) × \$10{,000    (USD)
```

3.3 Multi-Factor Residual Risk Weighting

When internal controls are mapped to a risk scenario, the system calculates a **Composite Control Effectiveness Factor (eta)**:

```
eta = {Design (1–5) × Operating (1–5){25 ∈ [0.04, 1.0]
```

The residual likelihood (L_{res}), residual impact (I_{res}), and net residual exposure are computed mathematically:

```
L_{res = max≤ft(1, \; round≤ft(L_{inh × (1 − 0.7 × eta)\right)\right)
```

```
I_{res = max≤ft(1, \; round≤ft(I_{inh × (1 − 0.5 × eta)\right)\right)
```

```
Residual Score (S_{res) = L_{res × I_{res
```

```
Residual SLE = S_{res × \$10{,000
```

3.4 Open FAIR Probabilistic Monte Carlo Simulation Engine

- **Loss Event Frequency (LEF):** Modeled as a **Poisson Process** with parameter λ = (L / 5) * 2.5 annual events.
- **Loss Magnitude (LM):** Modeled as a **Lognormal Distribution** using the Box-Muller transform:

```
Z = \sqrt{−2\ln(U_1) \cos(2\pi U_2) ⇒ Magnitude = SLE × \exp(0.4 Z − 0.08)
```

- **10,000 Iteration Loop:** Simulates 10,000 operational years to compute **Annualized Loss Expectancy (ALE)** and **95% Value at Risk (VaR 95)**.

4. Track A: Academic Project Defense (20-Minute Viva Blueprint)

Timeline	Phase & Screen	Key Theoretical Points to Explain
:---	:---	:---
0:00 - 3:00	**1. Problem Statement & Motivation**	• Spreadsheets lack segregation of duties, audit trails, and automated residual calculations. • Commercial tools (ServiceNow, RSA Archer) cost $50k+/year and take months to deploy. • Pericope ERM bridges this gap with a single-schema, three-tier cloud-native design.
3:00 - 7:00	**2. 3-Tier Resilient Architecture**	• **Tier 1 (Client):** Next.js 15 App Router + TanStack Query caching + LocalStore offline engine. • **Tier 2 (BFF API):** Node.js Express proxy with 8s bounded timeout, keyboard-mash sanitization, and in-memory shadow store fallback. • **Tier 3 (Database):** Oracle Autonomous Database (ADW) exposed through ORDS REST endpoints.
7:00 - 11:00	**3. Mathematical Scoring Engine**	• **Qualitative Model:** S = L x I in [1, 25] mapped to 4 severity bands. • **Quantitative Exposure:** SLE = S x $10,000 (Single Loss Expectancy in USD). • **Multi-Factor Residual Formula:** eta = (Design x Operating) / 25, calculating actual risk reduction. • **FAIR Monte Carlo Simulation:** 10,000 iterations computing Annualized Loss Expectancy (ALE) and 95% Value at Risk (VaR).
11:00 - 15:00	**4. Database Hardening & Remediation**	• Show `db/fix_pericope_erm.sql`. • Explain how ORA-04098 invalid trigger was resolved using **autonomous transactions (PRAGMA AUTONOMOUS_TRANSACTION)** so audit logging never aborts business DML. • Explain sequence auto-resync (STEP 6B) preventing ORA-00001 PK collision.
15:00 - 18:00	**5. RBAC & SOX 404 Auditability**	• Show `X-User-*` header attribution. • Demonstrate live role switching: **Auditor (Lin Wei)** gets read-only view with immutable audit log; **Manager (Priya Sharma)** has approval authority.
18:00 - 20:00	**6. Conclusion & Viva Q&A**	• Summarize research paper findings, performance benchmarks, and answer panel questions.

5. Track B: Enterprise Client Sales Demo (15-Minute Business Pitch)

Timeline	Phase & Screen	Client Value Proposition
:---	:---	:---
0:00 - 2:00	**1. Executive Cockpit (/dashboard)**	*"Here is the Executive Dashboard showing gross financial exposure ($SLE), control effectiveness (78%), and active RCSA cycles at a glance."*
2:00 - 5:00	**2. Excel / CSV Migration (/rcsa/identification)**	*"You don't need to rebuild your registers. Download our CSV template or upload your existing spreadsheets directly into Pericope with instant validation."*
5:00 - 8:00	**3. 5x5 Heatmap & Residual Step-down (/heatmaps)**	*"Watch how risks are plotted across likelihood and impact. Switch between Inherent, Residual, and Trend views to see how internal controls reduce monetary exposure."*
8:00 - 11:00	**4. Continuous KRI Telemetry (/kri)**	*"Simulate an operational spike in IT outage hours from 4.0 to 14.5. Watch the indicator turn Red, trigger an alert, and log an immutable audit event."*
11:00 - 13:00	**5. SOX 404 RBAC & Audit Trail (/audit-trail)**	*"Demonstrate Segregation of Duties. Switch to Auditor persona — notice all create/delete buttons disappear and the full historical event log is accessible."*
13:00 - 15:00	**6. 1-Click Board Risk Pack (/reports)**	*"Click 'Print / Save as PDF' on the Executive Board Pack to generate a formatted quarterly risk committee deck."*

6. Click-by-Click Live Demonstration Walkthrough

Scene 1: Multi-Mode Corporate Sign-In

- Navigate to `http://localhost:3000`. If logged in, click user menu → **Sign out**.
- **Talking Point:** *"Pericope supports standard corporate credentials, Enterprise SSO, and one-click role persona testing."*
- Click **"Srivatsan B — Administrator"** or sign in with `srivatsan@pericope.local` / `Demo123!`.

Scene 2: Executive Dashboard

- Land on `/dashboard`.
- Point to the **4 KPI Panels**:
- **Active Risks:** 18
- **Single Loss Expectancy (SLE):** $1,280k
- **Control Coverage:** 78.4%
- **Assessment Completion:** 67%
- Hover over the **Trailing Risk Velocity** 6-month area chart.
- Point to the **Recent Risk Entries** ledger table with direct navigation links.

Scene 3: RCSA Lifecycle & Bulk Spreadsheet Migration

- Click **RCSA Hub** → **01 Setup** (`/rcsa/provisioning`).
- Point to the Stepper Bar: `01 Setup` → `02 Identify` → `03 Mitigation` → `04 Monitoring`.
- Click **"Demo starter packs"** → select **"Fintech & Banking Pack"** to demonstrate instant industry seeding.
- Click **"Open →"** on any assessment (e.g. `RCSA-1601` Finance & Treasury) → opens direct Assessment Details page (`/rcsa/provisioning/[id]`).
- Displays the linked risks for that exact assessment.
- Click **"Map Controls →"** on any risk → opens applied controls page to evaluate and mitigate the risk.
- Click **"Next Stage: Identify →"** or open `/rcsa/identification`.
- Click **"CSV Template"** → browser downloads `pericope_risk_register_template.csv`.
- Click **"Import CSV"** → select any sample `.csv` → preview table displays parsed statements, likelihood, impact, and SLE.
- Click **"Import Risks"** → toast confirms successful bulk import into database.

Scene 4: Interactive 5x5 Risk Heatmap

- Navigate to **Risk Analytics** → **5x5 Risk Heatmaps** (`/heatmaps`).
- Point out the clear coordinate axes:
- **Y-Axis (Likelihood):** `5 - Almost Certain` down to `1 - Rare`.
- **X-Axis (Impact):** `1 - Insignificant` up to `5 - Severe`.
- Toggle between **Inherent Exposure**, **Residual (Post-Control)**, and **Risk Velocity**.
- Click on any active cell with numbers → dialog modal opens listing the exact risk scenarios mapped to that score.

6. Live Demonstration Walkthrough (Continued)

Scene 5: Continuous KRI Telemetry & Breach Alert Simulation

- Navigate to **Key Risk Indicators** (`/kri`).
- Point to the 4 operational metric cards (*Tracked indicators, Normal, Warnings, Red Breaches*).
- Find **"Unplanned IT Outage Hours"** (current value: 7.2 hrs/mo, status: Amber).
- Click the **Refresh/Update icon** → input value `14.5` → click **Update**.
- **Observe:**
- Status badge turns **Critical** / **Breach (Red)**.
- The mini trend line plots the new peak above the red reference line.
- Audit trail automatically captures the event.

Scene 6: Role-Based Access Control (RBAC) & Auditor Mode

- Open the top-right User Dropdown menu.
- Click **"Lin Wei (Auditor)"**.
- **Observe:**
- Amber banner appears: *"Auditor mode (read-only): You have view access to all records, control workpapers, and the audit log."*
- Navigate to `/rcsa/identification` or `/control-library` → notice that "+ Add Risk", "New control", and "Delete" buttons are hidden or disabled.
- Navigate to **Audit Trail** (`/audit-trail`).
- Point to the chronological table showing timestamps, actor names, action types (`CREATE`, `UPDATE`, `ROLE_CHANGE`), and results.
- Click **"Export CSV"** → exports complete compliance log.

Scene 7: 1-Click Executive Board Risk Report (PDF)

- Switch back to **Administrator** or navigate to **Reports** (`/reports`).
- Select **"Executive Board Risk Committee Pack"** (or click through any of the 8 dynamic reports in the catalog).
- Point out the 4 structured reporting sections:
- *1. Executive Exposure Summary*
- *2. Top High-Exposure Risk Scenarios Table*
- *3. Key Risk Indicator (KRI) Operational Thresholds*
- *4. SOX 404 & ISO 31000 Certification Sign-off*
- Click **"Print** / **Save as PDF"**.
- **Point out:** The print preview strips all browser navigation, buttons, and sidebars, rendering only the clean, full-width executive report.

7. Comprehensive Viva & Client Q&A Defense Bank (Part 1)

Q1: What makes your application "resilience-first"?

> **Answer:** *"Most web applications crash or freeze if their database times out. Pericope ERM implements an 8-second circuit breaker in the Node.js BFF (`server.js`). If Oracle ORDS fails or is slow, the BFF serves requests from an in-memory shadow store with synthetic IDs. Furthermore, client-side modules in `lib/localStore.ts` utilize browser localStorage with multi-tab storage listeners, allowing risk managers to continue working even during complete network outages."*

Q2: Why is Single Loss Expectancy (SLE) better than traditional scoring?

> **Answer:** *"Traditional GRC tools give ordinal scores like '16' or 'Red', which mean nothing to a CFO or Board of Directors. By formulating SLE = S x $10,000, we translate qualitative matrix coordinates into a tangible financial baseline ($160,000). This allows leadership to perform cost-benefit analysis on control investments (e.g. spending $20,000 on a control to mitigate $120,000 in risk)."*

Q3: How do you prevent audit triggers from crashing business transactions?

> **Answer:** *"In `fix_pericope_erm.sql`, we encapsulated the audit writer procedure `ERM_AUDIT_WRITE` inside `PRAGMA AUTONOMOUS_TRANSACTION`. It executes in a detached transaction thread with its own commit/rollback scope. Any audit logging exception is swallowed, ensuring the primary business operation (creating or editing a risk) is never aborted."*

Q4: How is Role-Based Access Control (RBAC) enforced?

> **Answer:** *"We enforce RBAC at two distinct boundaries: (1) On the client, React components verify `hasPermission()` from the user's active session, hiding unpermitted buttons; (2) On the API gateway (`server.js`), requests pass through permission middleware checking `X-User-Role` headers and returning HTTP 403 Forbidden for unauthorized actions."*

Q5: How does your Monte Carlo simulation work?

> **Answer:** *"We run 10,000 iterations modeling loss events as a Poisson process (λ) and loss magnitude as a Lognormal distribution. By aggregating simulated annual losses and sorting them, we compute the 95th percentile Value at Risk (VaR 95) and Annualized Loss Expectancy (ALE)."*

Q6: Can clients migrate their existing Excel risk registers?

> **Answer:** *"Yes. We built a native CSV spreadsheet parser in `/rcsa/identification`. Users can download our pre-formatted CSV template, paste their existing spreadsheet data, and upload it with instant multi-row preview and validation."*

7. Viva & Client Q&A Defense Bank (Part 2)

Q7: What testing and verification did you perform?

> **Answer:** *"We built an automated test runner (`qa_test_suite.mjs`) containing 12 unit and integration tests covering composite scoring bounds, Single Loss Expectancy, multi-factor residual calculations, FAIR Monte Carlo math, anti-junk keyboard mash heuristics, ORDS response normalizers, and local storage CRUD operations."*

Q8: How does your system handle input validation and malicious input?

> **Answer:** *"The API gateway applies regex-based anti-junk heuristics (`CONSONANT_RUN` and vowel ratio analysis) to reject keyboard-mash gibberish while permitting valid uppercase acronyms (e.g. `GDPR_SOC2`). All database writes are coerced and whitelisted against approved table schemas."*

Q9: What happens when records are imported with manual IDs in Oracle?

> **Answer:** *"Manual imports cause Oracle primary-key sequences to fall behind `MAX(UUID)`, resulting in `ORA-00001` unique constraint violations on future inserts. Our script (`fix_pericope_erm.sql`, Step 6B) automatically advances sequences to `MAX(UUID) + 1` to guarantee unique IDs."*

Q10: How do you support multi-framework compliance?

> **Answer:** *"Our Control Library maps controls across multiple regulatory frameworks simultaneously (e.g. ISO 27001, SOX Section 404, GDPR, and NIST SP 800-53), allowing organizations to test a control once and prove compliance across multiple standards."*

8. Operational Commands & Verification Cheat-Sheet

- **Start Backend API Server (Port 5000):** `node server.js`
- **Start Frontend Client (Port 3000):** `npm run dev`
- **Execute Automated QA Verification Suite:** `node qa_test_suite.mjs`
- **TypeScript Static Typecheck:** `npx tsc --noEmit`
- **Database Diagnostic Health Check:** `http://localhost:5000/health`